

PERSONAL DATA PROTECTION LAW

COMPLIANCE AUDIT REPORT

Kingdom of Saudi Arabia — SDAIA Framework

Client Name	Al-Noor Trading Co. Ltd.
Audit Type	PDPL Gap Assessment & Compliance Audit
Report Date	March 10, 2026
Audit Period	February 15 – March 5, 2026
Report Version	v1.0 — Confidential
Prepared By	Jupiter Cyber Defence
Lead Auditor	Syed Moiz Ahmed, CISA, CIPP/E

 **CONFIDENTIAL — FOR AUTHORIZED RECIPIENTS ONLY**

1.1 Engagement Overview

Jupiter Cyber Defence was engaged by Al-Noor Trading Co. Ltd to conduct a comprehensive PDPL compliance audit in accordance with the Kingdom of Saudi Arabia's Personal Data Protection Law (PDPL), issued by Royal Decree No. M/19 and enforced by the Saudi Data & AI Authority (SDAIA). The objective was to assess the organization's current data protection posture, identify compliance gaps, and provide a prioritized remediation roadmap.

1.2 Overall Compliance Score



1.3 Key Findings at a Glance

The audit identified five (5) critical non-conformities that expose the organization to regulatory fines under PDPL Article 35, which prescribes penalties of up to SAR 5,000,000. Immediate remediation is required for the following:

#	Finding	PDPL Article	Severity	Status
F-01	No formal Privacy Policy published on company website	Art. 7	Critical	Open
F-02	Personal data collected without valid consent mechanisms	Art. 5	Critical	Open
F-03	No Data Protection Officer (DPO) appointed	Art. 30	Critical	Open
F-04	Absence of data breach notification procedures	Art. 19	Critical	Open
F-05	Customer data shared with third parties without Data Processing Agreements	Art. 15	Critical	Open
F-06	No formal data retention and deletion policy in place	Art. 18	High	Open
F-07	Employee personal data processed without documented legal basis	Art. 5	High	Open
F-08	Website cookies not disclosed or consent-managed	Art. 7	Medium	Open
F-09	No staff awareness training on PDPL conducted	Art. 30	Medium	Open
F-10	CCTV footage retention period undefined	Art. 18	Low	Open

2. Scope & Methodology

2.1 Audit Scope

This audit covered all personal data processing activities conducted by Jupiter Cyber Defence across its Riyadh head office and online sales platform. The following data subjects and processing activities were included in scope:

- Customer personal data: names, contact details, purchase history, payment information
- Employee personal data: HR files, payroll data, access credentials
- Supplier and vendor contact information
- Website visitor data: cookies, analytics, contact form submissions
- CCTV footage captured at business premises

2.2 Audit Methodology

The audit was conducted in four phases using a hybrid approach combining document review, stakeholder interviews, and technical assessments:

Phase	Activity	Description
Phase 1	Initiation	Kick-off meeting, data collection request, documentation review of existing policies and procedures
Phase 2	Assessment	Stakeholder interviews with CEO, IT Manager, HR, and Sales team; PDPL gap analysis against SDAIA framework
Phase 3	Technical Review	Vulnerability scan, website compliance check, data flow mapping, access control review
Phase 4	Reporting	Findings consolidation, risk rating, remediation roadmap development, report delivery

3. Detailed Findings

F-01 No Privacy Policy Published

PDPL Reference	Severity	Effort to Fix	Priority	Status
Art. 7 — Transparency	Critical	Low — 1–2 weeks	Immediate	Open
Description The organization does not publish a Privacy Policy on its website or provide one to customers at the point of data collection. PDPL Article 7 requires data controllers to inform data subjects of the purposes, legal basis, and their rights regarding personal data processing prior to or at the time of collection.				
Recommendation Draft and publish a comprehensive Arabic and English Privacy Policy on the company website within 30 days. The policy must include: data types collected, processing purposes, legal basis, retention periods, data subject rights, and contact details for the DPO.				

F-02 No Valid Consent Mechanism

PDPL Reference	Severity	Effort to Fix	Priority	Status
Art. 5 — Lawful Basis	Critical	Medium — 2–4 weeks	Immediate	Open
Description The website collects customer personal data via forms without presenting a consent checkbox or disclosing processing purposes. PDPL requires that at least one valid legal basis exists for each processing activity. Where consent is used as the legal basis, it must be freely given, specific, informed, and unambiguous.				
Recommendation Implement consent checkboxes on all web forms. Conduct a data processing inventory to identify all processing activities and assign a valid legal basis (consent, contract, legal obligation, or legitimate interest) to each. Document this in a Record of Processing Activities (RoPA).				

F-03 No Data Protection Officer Appointed

PDPL Reference	Severity	Effort to Fix	Priority	Status
Art. 30 — DPO Requirement	Critical	Medium — 3–6 weeks	Immediate	Open
Description The organization has not appointed a Data Protection Officer (DPO). Under PDPL, entities that process personal data at scale or process sensitive categories of data are required to designate a DPO responsible for oversight of data protection compliance.				
Recommendation Appoint an internal DPO or engage an outsourced DPO service. Register the DPO with SDAIA via the official portal. Ensure the DPO has access to senior management and is not subject to conflicts of interest.				

F-04 No Data Breach Notification Procedure

PDPL Reference Art. 19 — Breach Notification	Severity Critical	Effort to Fix Medium — 2–3 weeks	Priority Immediate	Status Open
Description				
No documented incident response or data breach notification procedure exists. PDPL Article 19 requires that data controllers notify SDAIA of personal data breaches within 72 hours of becoming aware, and notify affected data subjects without undue delay when the breach poses a high risk to their rights.				
Recommendation				
Develop and implement a Data Breach Response Plan including: breach classification criteria, 72-hour SDAIA notification workflow, data subject notification templates, evidence preservation procedures, and post-incident review process.				

F-05 Third-Party Data Sharing Without DPAs

PDPL Reference Art. 15 — Data Processor Obligations	Severity Critical	Effort to Fix Medium — 4–6 weeks	Priority High	Status Open
Description				
Audit evidence shows that customer personal data is shared with three third-party service providers (logistics, email marketing, cloud hosting) without executed Data Processing Agreements (DPAs). PDPL requires that any transfer of personal data to a third party is governed by a written agreement that mandates data protection obligations.				
Recommendation				
Execute PDPL-compliant Data Processing Agreements with all third-party processors within 45 days. Conduct a third-party data inventory to identify all vendors receiving personal data. Agreements must include: processing scope, security obligations, sub-processor restrictions, and data deletion requirements.				

4. Remediation Roadmap

The following table presents a prioritized 90-day remediation plan. Actions are sequenced by criticality and interdependency. The organization should assign an internal owner to each action and track progress weekly.

Ref	Action	Owner	Deadline	Finding	Effort
R-01	Publish Privacy Policy (Arabic + English)	CEO / Legal	Day 14	F-01	Low
R-02	Appoint DPO (internal or outsourced)	CEO	Day 21	F-03	Medium
R-03	Add consent checkboxes to all web forms	IT Manager	Day 21	F-02	Low
R-04	Draft Data Breach Response Plan	DPO / IT	Day 30	F-04	Medium
R-05	Execute DPAs with all 3 third-party vendors	Legal / DPO	Day 45	F-05	Medium
R-06	Complete Record of Processing Activities (RoPA)	DPO	Day 45	F-02, F-07	Medium
R-07	Implement cookie consent banner on website	IT Manager	Day 30	F-08	Low
R-08	Conduct PDPL staff awareness training	DPO / HR	Day 60	F-09	Low
R-09	Establish data retention and deletion schedule	DPO / IT	Day 75	F-06	Medium
R-10	Define CCTV retention policy and signage	Facilities / DPO	Day 75	F-10	Low
R-11	Conduct PDPL re-assessment audit	Jupiter CD	Day 90	All	High

5. Appendix — PDPL Control Assessment

The following table summarizes the assessment result for each PDPL control domain evaluated during this audit.

Control Domain	PDPL Articles	Result	Notes
Privacy Policy & Transparency	Art. 7	Fail	No policy published
Lawful Basis for Processing	Art. 5	Fail	No consent mechanism
Data Subject Rights Procedures	Art. 8–14	Partial	No formal process
Sensitive Data Handling	Art. 6	Pass	No sensitive data processed
Third-Party Data Sharing Controls	Art. 15	Fail	No DPAs in place
Cross-Border Data Transfer Controls	Art. 16–17	Pass	No cross-border transfers
Data Retention & Deletion Policy	Art. 18	Fail	Policy absent
Data Breach Response	Art. 19	Fail	No procedure exists
Data Protection Officer	Art. 30	Fail	Not appointed
Privacy by Design	Art. 20	Partial	Partial implementation
Technical Security Controls	Art. 20	Partial	Basic controls, gaps found
Staff Awareness & Training	Art. 30	Fail	No training conducted
Cookie & Website Compliance	Art. 7	Fail	No cookie banner
Records of Processing Activities	Art. 28	Fail	RoPA not maintained
Vendor / Processor Management	Art. 15	Fail	No vendor assessments
Physical Security Controls	Art. 20	Pass	Office access controls adequate
CCTV & Surveillance Policy	Art. 18	Partial	Retention undefined
HR Data Processing Controls	Art. 5	Partial	No documented legal basis
Data Minimization Practices	Art. 5	Partial	Some excess collection noted
Incident Management Process	Art. 19	Fail	No formal process

5.2 About This Report

This report was prepared solely for the use of Jupiter Cyber Defence, and may not be reproduced or distributed to any third party without written consent from Jupiter Cyber Defence. The findings and recommendations are based on information available at the time of the audit and represent a point-in-time assessment.

For questions regarding this report, please contact:

- Email: info@jupitercyberdefence.com
- Phone: +46 767617752
- Website: jupitercyberdefence.com